

4. Arquetipos de rooms

Reconocer el tipo de room y elegir una ruta de trabajo.

Un arquetipo no es una regla absoluta, pero ayuda a decidir por donde empezar. Si una room mezcla varios patrones, resuelve primero el que te de identidad, credenciales o una shell inicial.

Arquetipo	Senales	Ruta recomendada
Web basica	80/443, login, rutas ocultas, uploads.	Discovery -> Burp -> LFI/SSTI/upload/IDOR/creds.
WordPress/CMS	wp-content, wp-login, plugins, temas.	WPScan -> usuarios -> plugins/temas -> creds/wp-admin -> RCE.
SQLi room	Parametros, errores SQL, login bypass.	Confirmar manual -> sqlmap con request -> dump -> hashes/RCE si aplica.
SMB/Linux mixta	445, shares, backups, usuarios reutilizables.	Shares -> loot -> cred reuse -> SSH/web/sudo.
Active Directory	53/88/389/445, dominio, DC.	Hosts/DNS -> usuarios -> spraying controlado -> Kerberos/BloodHound.
Linux privesc	Shell Linux sin root.	id/sudo -l -> SUID -> caps -> cron/systemd -> creds.
Windows privesc	Shell Windows sin admin.	whoami /priv -> servicios -> tareas -> registry -> creds.
Pivoting	Servicios localhost o red interna no accesible.	Rutas/interfaces -> ssh -L/-D, chisel o ligolo -> reenum interna.
Cracking/loot	Hashes, kdbx, id_rsa, zips, backups.	Convertir con *2john -> crackear -> cred reuse controlado.
CVE/exploit	Version concreta vulnerable.	Verificar version/config -> leer PoC -> check -> payload minimo.

Como usar esta tabla

- Elige el arquetipo por evidencia, no por intuicion: puertos, rutas, banners, usuarios o archivos.
- Si aparecen credenciales, salta a reutilizacion controlada y reenumeracion.
- Si no hay progreso en 20-30 minutos, usa la checklist de atasco antes de abrir exploits nuevos.